

KIT DE ENCUESTA INTEGRAL DE CIBERSEGURIDAD

Modelo ADAM: Evaluación de Riesgos, Vulnerabilidades, Penetración Testing, SIEM y Concienciación

Versión: 1.0

Fecha: Enero 2026

Clasificación: Uso Estratégico - Líderes de Seguridad, CISOs, Responsables GRC

Idioma: Español

MODELO DE ENCUESTA INTEGRAL

SECCIÓN 1: DATOS ORGANIZACIONALES Y CONTEXTO

1.1 Identificación Organizacional

- Nombre Organización: [_____]
- Sector/Industria: (Seleccionar)
 - [] Energía
 - [] Agua
 - [] Transporte
 - [] Telecomunicaciones
 - [] Financiero
 - [] Salud
 - [] Educación
 - [] Administración Pública
 - [] Industrial/Manufacturero
 - [] Retail/Comercio
 - [] Otro: [_____]
- Tamaño Organización:
 - [] Micro (≤ 10 empleados)
 - [] Pequeña (11-50 empleados)
 - [] Mediana (51-250 empleados)
 - [] Grande (251-1.000 empleados)
 - [] Muy Grande (> 1.000 empleados)
- ¿Es operador CRITIS (infraestructura crítica)?
 - [] Sí, operador esencial NIS2
 - [] Sí, operador importante NIS2
 - [] No, pero proveedor crítico
 - [] No aplica
- Responsable Encuesta (puesto):
 - [] CISO/Director Ciberseguridad
 - [] CTO/Director Técnico
 - [] Responsable GRC
 - [] Auditor Interno
 - [] Otro: [_____]

[] Otro: [_____]

Tamaño Organización:

[] Muy Grande (>1.000 empleados)

¿Es operador CRITIS (infraestructura crítica)?

[] No aplica

Responsable Encuesta (puesto):

SECCIÓN 2: GOBERNANZA Y ESTRATEGIA CIBERNÉTICA (Función NIST: GOBERNAR)

2.1 Política y Marco de Ciberseguridad

Pregunta: ¿Dispone su organización de una política de ciberseguridad formal, documentada y comunicada?

- [] Inexistente (0): Sin política documentada
- [] Inicial (1): Existe borrador, comunicación informal
- [] Gestionada (2): Política formal, algunos equipos conocen
- [] Definida (3): Política completa, comunicada a toda la organización, revisión anual
- [] Optimizada (4): Política viva, revisión periódica, integrada en onboarding, métricas de conocimiento

Validación: ¿Puede proporcionar copia de la política más reciente? (adjuntar o confirmar)

2.2 Asignación de Responsabilidades y Estructura

Pregunta: ¿Existe estructura clara de responsabilidades en ciberseguridad con roles definidos?

- [] Sin estructura (0): Responsabilidades difusas
- [] Ad hoc (1): Responsable único sin equipo formalizado
- [] Definida (2): Equipo de seguridad (3-5 personas), roles documentados
- [] Establecida (3): Estructura jerárquica clara, CISO con autoridad ejecutiva, comité seguridad con participación C-level
- [] Estratégica (4): CISO en Junta Directiva, reporta directamente CEO, presupuesto independiente, autoridad en decisiones críticas

Indicador Asociado: Autoridad Ejecutiva del CISO (KPI)

2.3 Cumplimiento Normativo: NIS2, Ley Ciberresiliencia, ENS, ISO 27001

Pregunta: ¿Cuál es el estado de cumplimiento normativo de su organización?

Normativa	No Aplica	Planificación	En Ejecución	Parcialmente Cumplido	Totalmente Cumplido
NIS2 (si operador esencial/importante)	☐	☐	☐	☐	☐
Ley Ciberresiliencia (si fabricante/desarrollador)	☐	☐	☐	☐	☐
ENS (sector público)	☐	☐	☐	☐	☐
ISO 27001	☐	☐	☐	☐	☐
ISO 27002	☐	☐	☐	☐	☐
GDPR	☐	☐	☐	☐	☐
CMMC 2.0 (si contratista DoD/similares)	☐	☐	☐	☐	☐

Follow-up: Para normativas "Totalmente Cumplidas," ¿dispone de certificación válida? (Incluir fecha validez)

2.4 Modelo de Gobernanza de Riesgos: NIST CSF, FAIR, Metodología de Evaluación

Pregunta: ¿Qué metodología utiliza para evaluación y gestión de riesgos cibernéticos?

- ☐ Sin metodología (0): Evaluación informal, esporádica
- ☐ Ad hoc (1): Evaluaciones ocasionales, sin estructura
- ☐ Inicial (2): Utiliza NIST CSF básico o ISO 27001, anual
- ☐ Establecida (3): NIST CSF 2.0 + FAIR / metodología de evaluación cuantitativa, semestral
- ☐ Avanzada (4): NIST CSF 2.0 + FAIR + Wardley Maps, evaluación continua con IA, risk scoring automatizado

Validación: ¿Puede compartir último informe de evaluación de riesgos? (Fecha, metodología empleada)

2.5 Inversión y Presupuesto Ciberseguridad

Pregunta: ¿Cuál fue el presupuesto de ciberseguridad en el último año fiscal (2025)?

- Presupuesto total (€):
- % sobre ingresos anuales: %
- % sobre TI total: %

Contexto Comparativo (Benchmark)

- Micro/Pequeña (no CRITIS): 0.5-1% ingresos
- Mediana: 1-2% ingresos
- Grande (CRITIS): 2-4% ingresos
- Muy Grande (CRITIS crítica): >4% ingresos

Pregunta Adicional: ¿Se prevé aumento de presupuesto 2026?

- ☐ No (mantener)
- ☐ Sí, <10%
- ☐ Sí, 10-25%
- ☐ Sí, 25-50%
- ☐ Sí, >50%

SECCIÓN 3: GESTIÓN DE VULNERABILIDADES Y ANÁLISIS DE RIESGOS

3.1 Inventario de Activos y Superficie de Ataque

Pregunta: ¿Dispone de inventario completo y actualizado de activos críticos?

- ☐ Inexistente (0): Sin inventario formalizado
- ☐ Parcial (1): Inventario manual, 30-40% cobertura
- ☐ Básico (2): Herramienta CMDB/ITSM, 60-70% cobertura, actualizaciones trimestrales
- ☐ Completo (3): Inventario centralizado, 90%+ cobertura, actualizaciones mensuales, categorización de criticidad
- ☐ Optimizado (4): Inventario en tiempo real con ITSM + APM (Application Performance Management), 100% cobertura, clasificación por business impact, asset risk scoring

KPI Asociado: Porcentaje de Cobertura de Activos Monitorizados

3.2 Evaluación de Vulnerabilidades: Procesos, Frecuencia, Herramientas

Pregunta: ¿Cómo realiza evaluación de vulnerabilidades en su infraestructura?

Aspecto	Descripción	Implementado
Herramientas de Escaneo	Scanners automatizados (Nessus, Qualys, OpenVAS, etc.)	☐ Sí ☐ No ☐ Parcial
Cobertura de Escaneo	% de sistemas escaneados regularmente	[__]%
Frecuencia	Escaneos programados	☐ Nunca ☐ Ad-hoc ☐ Mensual ☐ Quincenal ☐ Semanal
Scope del Escaneo	Sistemas evaluados	☐ Solo perimetral ☐ Perimetral + interno ☐ Perimetral + interno + OT
Validación Manual	Revisión humana de resultados	☐ No ☐ Ocasional ☐ Sistemática
Exclusiones Documentadas	Control de cambios en scope	☐ No ☐ Informal ☐ Formalizado

3.3 Gestión del Ciclo de Vida de Vulnerabilidades: Priorización, Remediación, Tracking

Pregunta: ¿Qué sistema utiliza para priorización y remediación de vulnerabilidades?

- ☐ Sin sistema (0): "Parche cuando se puede"
- ☐ Manual (1): Excel, priorización por criticidad CVSS únicamente
- ☐ Inicial (2): Sistema ticketing básico, CVSS score, sin correlación contexto
- ☐ Avanzado (3): Plataforma VM dedicada, CVSS + EPSS + asset context, SLA por severidad definido
- ☐ Optimizado (4): Plataforma VM integrada con SIEM, CVSS + EPSS + contexto + threat intel, SLA automatizado, predictive remediation

Métricas de Remediación:

- % vulnerabilidades críticas remediadas en 30 días: []%
- Tiempo promedio remediación crítica (días): [] días
- Vulnerabilidades pendientes críticas: [__] (absoluto)

3.4 Scoring de Vulnerabilidades: CVSS vs EPSS

Pregunta: ¿Utiliza EPSS (Exploit Prediction Scoring System) además de CVSS para priorización?

- ☐ Solo CVSS (Tradicional): Score 0-10 teórico (criticidad)
- ☐ CVSS + contexto manual: CVSS + evaluación humana heurística
- ☐ Híbrido exploratorio: CVSS + algunos elementos EPSS manual
- ☐ CVSS + EPSS integrado: CVSS (severidad teórica) + EPSS (probabilidad real explotación 30d), decisión dual
- ☐ CVSS + EPSS + SSVC + threat intel: Scoring contextual múltiple + Stakeholder-Specific Vulnerability Categorization + feeds TTI

Entendimiento CVSS vs EPSS:

- **CVSS 0-10:** Mide severidad técnica (escala teórica, estática)
- **EPSS 0-1 (0-100%):** Estima probabilidad explotación real próximos 30d (datos + ML, dinámico)

Conclusión Esperada: EPSS complementa CVSS para priorización basada en riesgo real vs. severidad teórica

3.5 Análisis de Brechas e Identificación de Deuda Técnica

Pregunta: ¿Realiza análisis periódico de brechas vs. marcos de referencia (NIST, ISO, CIS)?

- ☐ No (0): Sin evaluación estructura
- ☐ Ad hoc (1): Evaluación ocasional, sin documentación
- ☐ Anual (2): Gap analysis formalizado, anual, contra NIST/ISO 27001
- ☐ Semestral (3): Gap analysis semestral contra NIST CSF 2.0 + estándar sectorial, documentado
- ☐ Continuo (4): Gap analysis trimestral + continuous compliance scanning, alertas automáticas ante nuevos requisitos

Deuda Técnica Identificada:

- **Número de brechas críticas:**
- **Número de brechas altas:**
- **Presupuesto estimado remediación (€):**

SECCIÓN 4: PRUEBAS DE PENETRACIÓN Y VALIDACIÓN DE SEGURIDAD

4.1 Programa de Testing: Penetration Testing y Red Team

Pregunta: ¿Realiza pruebas de penetración (pentest) de su infraestructura?

- ☐ Nunca (0): Sin testeo externo
- ☐ Ocasional (1): Pentest ad hoc cada 2-3 años
- ☐ Anual (2): Pentest externo anual, scope limitado (perimetral)
- ☐ Semestral (3): Pentest externo semestral + internal pentest anual, scope completo, red team ejercicios
- ☐ Continuo (4): Pentest anual + internal pentest semestral + red team trimestral + bug bounty program activo + adversary simulation mensual

Detalles Pentest:

- **Última prueba:** (fecha)
- **Tipo:** ☐ Externo ☐ Interno ☐ Híbrido ☐ Caja Negra ☐ Caja Blanca ☐ Caja Gris
- **Proveedor:**
- **Hallazgos críticos encontrados:**
- **% hallazgos remediados (post-prueba):** %
- **Tiempo promedio remediación (días):** días

4.2 Scope de Testing: Cobertura de Sistemas Críticos

Pregunta: ¿Qué scope incluye su programa de testing?

Componente	Incluido	Frecuencia
Aplicaciones web	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral
API (REST/SOAP)	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral
Infraestructura cloud	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral
OT/SCADA	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral
Componentes supply chain	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral
Mobile (iOS/Android)	☐ Sí ☐ No ☐ Parcial	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral

4.3 Resultados de Testing: Métricas de Seguridad Validada

Pregunta: Resuma resultados de últimos 12 meses de testing:

Métrica	Valor	Benchmark
Vulnerabilidades encontradas (total)		Esperado: 15-30 pentest anual
Críticas		Esperado: 0-2 pentest anual
Altas		Esperado: 2-5 pentest anual
Medias		Esperado: 5-10 pentest anual
Bajas		Esperado: >5 pentest anual
% remediadas en 30 días	%	Target: >80% críticas
Tiempo promedio remediación	días	Target: <30d críticas

4.4 Validación de Controles: Post-Remediation Testing

Pregunta: ¿Realiza validación de que controles remediados sean efectivos?

- ☐ No (0): Confianza en reporte de corrección
- ☐ Manual (1): Verificación ocasional informal
- ☐ Sistemática (2): Re-testing de hallazgos corregidos, documentado, 80%+ validación
- ☐ Automática (3): Re-testing automático post-remediación, 100% validación, integrado con SIEM
- ☐ Continua (4): Validación automática continua + regression testing, alertas de degradación

SECCIÓN 5: MONITORIZACIÓN Y GESTIÓN DE INFORMACIÓN DE SEGURIDAD (SIEM)

5.1 Arquitectura SIEM: Existencia, Cobertura, Centralización

Pregunta: ¿Dispone de solución SIEM centralizada?

- ☐ No (0): Sin SIEM o monitorización local únicamente
- ☐ Parcial (1): SIEM en evaluación/piloto, coverage <30% infraestructura
- ☐ Básica (2): SIEM implementada, coverage 60-70%, logs centralizados, alertas básicas
- ☐ Establecida (3): SIEM maduro, coverage 90%+, reglas de detección optimizadas, correlation rules, alertas accionables
- ☐ Avanzada (4): SIEM + SOAR (Security Orchestration Automation Response), coverage 100%, ML/IA detección, playbooks automation, UEBA integrada

Solución SIEM (si existe): [____] (Splunk, QRadar, LogRhythm, ArcSight, etc.)

5.2 Fuentes de Datos Centralizadas: Scope de Logs Recolectados

Pregunta: ¿Qué tipos de eventos/logs centraliza en SIEM?

Fuente	Centralizada	Cobertura	Retención
Firewalls (perimetral)	☐ Sí ☐ No	[____]%	[____] días
Endpoints (EDR/antivirus)	☐ Sí ☐ No	[____]%	[____] días
Servidores (SO logs)	☐ Sí ☐ No	[____]%	[____] días
Aplicaciones críticas	☐ Sí ☐ No	[____]%	[____] días
Autenticación (AD, IAM)	☐ Sí ☐ No	[____]%	[____] días
Cloud (AWS/Azure/GCP)	☐ Sí ☐ No	[____]%	[____] días
OT/ICS	☐ Sí ☐ No	[____]%	[____] días
Bases de Datos	☐ Sí ☐ No	[____]%	[____] días
Proxies/DLP	☐ Sí ☐ No	[____]%	[____] días
Threat feeds (ATI)	☐ Sí ☐ No	N/A	N/A

KPI Asociado: % de Cobertura de Monitorización (Target: >90%)

5.3 Detección de Amenazas: Reglas, Correlaciones, Alertas

Pregunta: ¿Cómo detecta amenazas mediante SIEM?

- ☐ Manual (0): Análisis humano esporádico de logs
- ☐ Básica (1): 20-50 reglas simples, sin correlación
- ☐ Intermedia (2): 50-150 reglas + correlaciones simples, 10-20 alertas/día promedio
- ☐ Avanzada (3): 150-300 reglas + correlaciones multi-paso, ML/IA dirigidas, 20-50 alertas/día, umbral optimizado
- ☐ Predictiva (4): 300+ reglas + correlaciones complejas + UEBA + threat intel integration, ML/IA predictiva, <5 false positives/día, >95% relevancia

Métricas de Detección:

- Número de reglas activas: []
- Alertas generadas/día (promedio): []
- % alertas accionables (relevantes): []%
- Falsos positivos/día (promedio): []

5.4 Métricas Operacionales SIEM: MTTD, Latencia, Disponibilidad

Pregunta: ¿Cuáles son métricas operacionales de su SIEM?

Métrica	Valor	Target
MTTD (Mean Time To Detect)	[_] min	<15min crítica
Latencia promedio ingesta	[_] seg	<5seg
Disponibilidad SIEM (uptime)	[_]%	>99.5%
% eventos procesados en tiempo real	[_]%	>95%
Volumen eventos/segundo pico	[_] EPS	Capacidad: [_] EPS

5.5 Integración con Herramientas de Respuesta: SOAR, Playbooks, Tickets

Pregunta: ¿Cómo integra SIEM con herramientas de respuesta a incidentes?

- [] Desconectada (0): Manual, tickets creados manualmente post-alerta
- [] Básica (1): SIEM → ticketing automático, sin enriquecimiento
- [] Intermedia (2): SIEM → SOAR basic → ticketing automático + información enriquecida
- [] Avanzada (3): SIEM → SOAR → playbooks automáticos (bloqueo IP, aislamiento, etc.) + ticketing + notificación
- [] Orquestada (4): SIEM → SOAR → playbooks inteligentes con aprobación ejecutiva + feedback learning + closed-loop automation

Herramientas Integradas (si aplica):

- [] SOAR (Splunk Phantom, Demisto, Rapid7, etc.): []
- [] Ticketing (Jira, ServiceNow, etc.): []
- [] EDR/XDR (CrowdStrike, Microsoft Defender, Sophos, etc.): []

SECCIÓN 6: RESPUESTA A INCIDENTES

6.1 Plan de Respuesta a Incidentes: Existencia, Actualización, Cobertura

Pregunta: ¿Dispone de plan documentado de respuesta a incidentes?

- ☐ No (0): Sin plan formalizado
- ☐ Borrador (1): Plan en elaboración, sin validación
- ☐ Documentado (2): Plan escrito, roles definidos, procedimientos básicos, actualización anual
- ☐ Validado (3): Plan probado mediante simulacros anuales, métricas de respuesta definidas (RTO/RPO), integrado con DR/CR
- ☐ Optimizado (4): Plan vivo (actualización semestral), simulacros trimestrales, tabletops semestrales, métricas reales vs. planeado, lecciones aprendidas integradas

Validación: ¿Puede compartir copia del plan más reciente? (adjuntar o confirmar versión/fecha)

6.2 Estructura de Respuesta: Equipos, Roles, Responsabilidades

Pregunta: ¿Cuál es estructura del equipo de respuesta a incidentes?

Rol	Asignado	Titular	Backup
Incident Commander	☐ Sí ☐ No	[]	[]
Forensics Lead	☐ Sí ☐ No	[]	[]
Comms Lead	☐ Sí ☐ No	[]	[]
Executive Sponsor	☐ Sí ☐ No	[]	[]
Legal/Compliance	☐ Sí ☐ No	[]	[]
Técnicos SOC/DevSecOps	☐ Sí ☐ No	[] personas	[] personas

Comité de Crisis:

- ☐ Existe y es activado en incidentes críticos
- ☐ No formalizado

6.3 Notificación y Comunicación de Incidentes: Plazos, Canales

Pregunta: ¿Cuál es procedimiento de notificación post-incidente?

Destinatario	Plazo	Responsable
Directiva interna (C-level)	[] horas	[]
Junta/Consejo	[] horas	[]
Autoridades (AEPD/CNI/DSN)	[] horas	[]
Clientes/Partners afectados	[] horas	[]
Medios (si relevante)	[] horas	[]

Cumplimiento Normativo:

- NIS2: 24h inicial, 72h preliminar, 30d informe completo
- GDPR: 72h a AEPD post-descubrimiento

Pregunta de Validación: ¿Ha reportado incidentes los últimos 12 meses?

- ☐ No

- ☐ Sí, incidentes

6.4 Métricas de Respuesta: MTTD, MTTC, MTTR

Pregunta: ¿Cuáles son métricas históricas de respuesta a incidentes?

Métrica	Última Crisis (Ejemplo)	Promedio 12m	Target
MTTD (Mean Time To Detect)	horas	horas	<1 hora
MTTC (Mean Time To Contain)	horas	horas	<4 horas
MTTR (Mean Time To Recover)	horas	horas	<24 horas
Numero de falsos positivos generados			<5%

SECCIÓN 7: CAPACITACIÓN Y CONCIENCIACIÓN EN CIBERSEGURIDAD

7.1 Programa de Concienciación: Estructura, Cobertura, Métricas

Pregunta: ¿Dispone de programa formalizado de concienciación en ciberseguridad?

- ☐ No (0): Sin programa estructurado
- ☐ Ad hoc (1): Eventos esporádicos, sin métrica
- ☐ Básico (2): Programa anual 1-2 módulos, participación manual, tasa asistencia <60%
- ☐ Establecido (3): Programa semestral 4-6 módulos, plataforma LMS, 80%+ participación, evaluaciones básicas
- ☐ Avanzado (4): Programa continuo (mensual) 8+ módulos, LMS integrada con gamificación, participación >95%, evaluaciones adaptativas, ROI medible

Plataforma LMS (si existe): (Moodle, SAP SuccessFactors, LinkedIn Learning, etc.)

7.2 Contenidos de Capacitación: Tópicos Cubiertos

Pregunta: ¿Qué tópicos cubre su programa de concienciación?

Tema	Incluido	Frecuencia	Horas/Año
Phishing & Social Engineering	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Password Management & MFA	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Protección de Datos Personales (GDPR)	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Incidentes de Seguridad & Reporte	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Seguridad OT/IoT	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Ciberdelincuencia & Ransomware	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Zero Trust & VPN	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Cloud Security & BYOD	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Compliance & Auditoría	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h
Seguridad en Supply Chain	☐ Sí ☐ No	☐ N/A ☐ Anual ☐ Semestral ☐ Trimestral	[] h

Horas Totales Capacitación/Año: [] horas

7.3 Simulaciones de Phishing: Programa, Métricas, ROI

Pregunta: ¿Realiza simulaciones de phishing para medir concienciación?

- ☐ No (0): Sin programa
- ☐ Ocasional (1): Simulaciones ad hoc, resultados no documentados
- ☐ Periódica (2): Simulaciones trimestrales, métricas básicas (click rate), feedback limitado
- ☐ Estructurada (3): Simulaciones mensuales, métricas completas (click, reporting, form submission), feedback inmediato + microtraining
- ☐ Predictiva (4): Simulaciones semanales con IA adaptativa, correlación a incidentes reales, ROI cuantificado, departamentos high-risk priorizados

Métricas Phishing (últimos 12 meses):

Métrica	Valor	Benchmark
Phish-Prone Percentage (% empleados que clikean)	[__]%	<15% bueno, <5% excelente
Net Reporter Score (NRS)	[__]	>10% reporting = muy bueno
Click-to-Form Completion Ratio (CFCR)	[__]%	<10% buen nivel
Tendencia YoY	[] Mejora [] Estable [] Empeora	Target: Mejora continua

Conclusión Esperada: Reducción 50%+ en click rates post-training (benchmark: 12 meses)

7.4 Capacitación Especializada: Roles de Alto Riesgo

Pregunta: ¿Realiza capacitación diferenciada para roles de alto riesgo?

Rol/Departamento	Capacitación Especializada	Frecuencia
Ejecutivos/C-level	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral
Finanzas (transferencias, pagos)	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral
HR/Nóminas	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral
Acceso a Datos Sensibles	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral
Desarrolladores/DevSecOps	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral
Operaciones TI/SysAdmins	[] Sí [] No	[] N/A [] Anual [] Semestral [] Trimestral

7.5 Métricas de Participación y Efectividad

Pregunta: ¿Cuáles son métricas de participación y efectividad de concienciación?

Métrica	Valor	Target
% participación en programas	[__]%	>90%
% completación de módulos	[__]%	>85%
Tasa de evaluación aprobatoria	[__]%	>80%
Cambio en comportamiento riesgoso (YoY)	[__]%	Reducción >20%
Reportes de phishing generados	[__]	Aumento = bueno
Incidentes por social engineering (YoY)	[__]	Reducción esperada
% empleados formados en último año	[__]%	>80%

SECCIÓN 8: INFRAESTRUCTURA TÉCNICA: PROTECCIÓN, DETECCIÓN, RESPUESTA

8.1 Arquitectura Defensiva: Capas de Control

Pregunta: ¿Qué capas de control defensivo implementa?

Capa	Tecnología	Cobertura	Estado
Perimetral	Firewalls, WAF, proxy	[__]%	[] Básico [] Intermedio [] Avanzado
Endpoint	EDR/XDR/Antivirus	[__]%	[] Básico [] Intermedio [] Avanzado
Red	IDS/IPS, microsegmentación	[__]%	[] Básico [] Intermedio [] Avanzado
Identidad	MFA, PAM, RBAC/ABAC	[__]%	[] Básico [] Intermedio [] Avanzado
Aplicación	DAST, SAST, secrets scanning	[__]%	[] Básico [] Intermedio [] Avanzado
Datos	DLP, cifrado, masking	[__]%	[] Básico [] Intermedio [] Avanzado
OT/ICS	Firewalls OT, barreras air-gap	[__]%	[] Básico [] Intermedio [] Avanzado

8.2 Autenticación y Control de Acceso

Pregunta: ¿Cuál es modelo de autenticación implementado?

- ☐ Básico (0): Solo usuario/contraseña, sin MFA
- ☐ Mejorado (1): MFA en acceso remoto únicamente, 50-60% usuarios
- ☐ Estándar (2): MFA en acceso remoto + críticos, 70-80% usuarios
- ☐ Avanzado (3): MFA universal >90% usuarios, Zero Trust iniciado, RBAC + ABAC en aplicaciones críticas
- ☐ Óptimo (4): MFA universal + biometría multifactor, Zero Trust total, ABAC en todas las aplicaciones, PAM para acceso privilegiado

Detalles MFA:

- % usuarios con MFA activo: ☐ %

- Métodos MFA activos: ☐ TOTP ☐ SMS ☐ Email ☐ Autenticador hardware ☐ Biometría ☐

Otro:

8.3 Gestión de Parches y Actualizaciones: Política, SLA, Automatización

Pregunta: ¿Cuál es política de parcheo?

- ☐ Ad hoc (0): "Cuando se puede"
- ☐ Manual (1): Notificación + aplicación manual, SLA no definido
- ☐ Programado (2): Ventanas de parche mensuales, SLA básico (críticas <30d)
- ☐ Automatizado (3): Parches automáticos en no-críticos, manuales en críticos con SLA (<7d críticas)
- ☐ Optimizado (4): Auto-patching con excepciones, SLA riguroso (<3d críticas, <14d altas), testing pre-prod automatizado

Métricas de Parcheo:

- % sistemas con parches críticos al día: ☐ %

- Tiempo promedio aplicación parches críticos: ☐ días

- % parches que requieren reboot: ☐ %

8.4 Encriptación: Datos en Tránsito y en Reposo

Pregunta: ¿Implementa encriptación en datos críticos?

Escenario	Implementado	Estándar
En tránsito (TLS/SSL)	☐ Sí ☐ No ☐ Parcial	TLS 1.2+ / 1.3
En reposo (AES-256)	☐ Sí ☐ No ☐ Parcial	AES-256
Bases de datos críticas	☐ Sí ☐ No ☐ Parcial	Cifrado nativo
Backups	☐ Sí ☐ No ☐ Parcial	Cifrado + MFA acceso
Cloud storage	☐ Sí ☐ No ☐ Parcial	End-to-end + BYOK
Dispositivos móviles	☐ Sí ☐ No ☐ Parcial	Full-disk + app encryption

SECCIÓN 9: CONTINUIDAD Y RECUPERACIÓN (DR/CR)

9.1 Plan de Disaster Recovery: Existencia, RTO/RPO, Actualización

Pregunta: ¿Dispone de plan de Disaster Recovery documentado?

- ☐ No (0): Sin plan
- ☐ Borrador (1): Plan en desarrollo
- ☐ Existente (2): Plan documentado, RTO/RPO definido para aplicaciones clave, actualización anual
- ☐ Validado (3): Plan probado anualmente mediante simulacro, métricas reales vs. objetivos, actualización semestral
- ☐ Optimizado (4): Plan vivo (actualización trimestral), simulacros semestrales, DR automatizado con failover sub-1h, Cyber Recovery separado de DR

Documentación: ¿Puede compartir resumen ejecutivo del plan? (versión/fecha)

9.2 RTO/RPO por Servicio Crítico

Pregunta: Defina RTO (Recovery Time Objective) y RPO (Recovery Point Objective):

Servicio Crítico	RTO	RPO	Criticidad
[Aplicación 1]	[__] h	[__] h	☐ Crítica ☐ Alta ☐ Media
[Aplicación 2]	[__] h	[__] h	☐ Crítica ☐ Alta ☐ Media
[Aplicación 3]	[__] h	[__] h	☐ Crítica ☐ Alta ☐ Media
Infraestructura Red	[__] h	[__] h	☐ Crítica ☐ Alta ☐ Media
Servicios Identidad (AD/IAM)	[__] h	[__] h	☐ Crítica ☐ Alta ☐ Media

Contexto NIS2: Operadores esenciales deben tener RTO/RPO ≤72h

9.3 Estrategia de Backup: Frecuencia, Pruebas, Segregación

Pregunta: ¿Cuál es estrategia de backup?

- ☐ Básica (0): Backups manuales, sin pruebas
- ☐ Programada (1): Backups diarios, pruebas ocasionales, 1 copia
- ☐ Redundante (2): Backups diarios + semanales, pruebas mensuales, 2 copias local+regional
- ☐ Defensiva (3): Backups diarios + semanales + mensuales, aire-gapped, encriptados, pruebas mensuales, 3 copias
- ☐ Resiliente (4): Backups diarios/semanales/mensuales, aire-gapped, encriptados con BYOK, copias múltiples geográficas, pruebas mensuales + adversary-resistant recovery testing

Detalles:

- **Frecuencia backup:** ☐ Horaria ☐ Diaria ☐ Semanal ☐ Mensual
- **% datos críticos en backup:** ☐ %
- **Última prueba de recuperación:** (fecha)
- **% prueba exitosa:** %
- **Backups separados (aire-gapped):** ☐ Sí ☐ No
- **Ubicación geográfica:** ☐ Mismo sitio ☐ Regional ☐ Múltiples regiones

SECCIÓN 10: SUPPLY CHAIN Y RIESGOS DE TERCEROS

10.1 Evaluación de Proveedores y Terceros

Pregunta: ¿Realiza evaluación de ciberseguridad a proveedores críticos?

- ☐ No (0): Sin evaluación
- ☐ Informal (1): Cuestionarios ad hoc
- ☐ Formal (2): Cuestionario estandarizado, revisión anual, proveedores críticos
- ☐ Integral (3): Evaluación formal anual + auditoría terceros en sitio cada 2 años + CAIQ (Consensus Assessments Initiative Questionnaire)
- ☐ Continua (4): Evaluación formal + auditoría anual + continuous monitoring (pentesting, vulnerability scans) + SBOM (Software Bill of Materials) requerido

Proveedores Críticos Evaluados: proveedores

10.2 Cláusulas de Seguridad en Contratos

Pregunta: ¿Incluye requisitos de ciberseguridad en contratos con proveedores?

Requisito	Incluido	Obligatorio	Auditado
ISO 27001 o equivalente	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Anual ☐ Bi-anual
Breach notification (24-72h)	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Sí ☐ No
Derecho de auditoría	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Anual ☐ Ad-hoc
Data protection cláusulas	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Sí ☐ No
Incident response SLA	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Trimestral ☐ Anual
Subcontratación controlada	☐ Sí ☐ No	☐ Obligatorio ☐ Recomendado	☐ Sí ☐ No

10.3 Gestión de SBOM y Vulnerabilidades Supply Chain

Pregunta: ¿Requiere y gestiona Software Bill of Materials (SBOM) de proveedores?

- ☐ No (0): Sin requisito SBOM
- ☐ Exploratorio (1): SBOM solicitado ocasionalmente
- ☐ Parcial (2): SBOM requerido a proveedores software críticos, análisis manual
- ☐ Establecido (3): SBOM requerido a todos proveedores software, análisis automático de vulnerabilidades, correlación a CVE/EPSS
- ☐ Avanzado (4): SBOM + composición de dependencias + transitive vulnerability scanning + continuous monitoring + proveedores que no proporcionan SBOM excluidos

SBOM Formatos Aceptados: ☐ CycloneDX ☐ SPDX ☐ SWID ☐ Otro: [_____]

SECCIÓN 11: CIBERSEGURIDAD OT/SCADA E IoT

11.1 Seguridad en Operaciones Tecnológicas (OT): Alcance, Control

Pregunta: ¿Implementa controles de ciberseguridad específicos para OT/SCADA?

- ☐ No (0): Sin protección especializada OT
- ☐ Perimetral (1): Firewall OT únicamente
- ☐ Segmentada (2): Red OT segregada, acceso controlado, sin SIEM OT
- ☐ Monitorizada (3): Red segregada + SIEM OT con IDS/IPS OT, patching controlado, monitorización 24/7
- ☐ Defensiva (4): Red segregada + SIEM OT + whitelisting de dispositivos + air-gap críticos + adversary simulation específica OT + Industrie 4.0 security by design

Infraestructura OT:

- **Dispositivos OT conectados:** ☐
- **Criticidad promedio:** ☐ Baja ☐ Media ☐ Alta
- **Última vulnerabilidad detectada:** [____] (tipo/fecha)

11.2 IoT y Dispositivos Perimetrales: Seguridad, Inventario, Parches

Pregunta: ¿Cómo gestiona seguridad de dispositivos IoT?

- ☐ Desatendida (0): Confianza en defaults del fabricante
- ☐ Básica (1): Inventario manual, firewalls de red
- ☐ Gestionada (2): Inventario centralizado, VLAN segregada para IoT, cambio de contraseñas default
- ☐ Monitorizada (3): Inventario + SIEM IoT + patching programado + anomaly detection basada en comportamiento
- ☐ Controlada (4): Inventario + SIEM IoT + patching OTA automático + whitelisting + EDR ligero en IoT capaz + zero-trust network access

Detalles IoT:

- **Número dispositivos IoT:** ☐
- **Cobertura inventario:** ☐%
- **% dispositivos parchados:** [____]%

SECCIÓN 12: ANÁLISIS FINANCIERO Y ROI

12.1 Cuantificación de Riesgos: Exposición Económica

Pregunta: ¿Ha realizado análisis cuantitativo de riesgos (FAIR, probabilidad × impacto)?

- ☐ No (0): Sin cuantificación
- ☐ Cualitativo (1): Alto/Medio/Bajo únicamente
- ☐ Semi-cuantitativo (2): Escala 1-5 con ponderación
- ☐ Cuantitativo básico (3): FAIR simplificado, 3-5 escenarios críticos analizados
- ☐ FAIR completo (4): FAIR riguroso para todos los activos críticos, actualización semestral, probabilidades basadas en datos históricos

Escenarios de Riesgo Cuantificados (últimos 12 meses):

Escenario	Probabilidad Anual	Impacto Estimado	Exposición (€)
[Escenario 1: Ransomware]	[]%	€ []	€ []
[Escenario 2: Fuga datos]	[]%	€ []	€ []
[Escenario 3: Interrupción servicio]	[]%	€ []	€ []
[Escenario 4: Compromiso supply chain]	[]%	€ []	€ []
EXPOSICIÓN TOTAL RIESGO			€ []

12.2 Retorno de Inversión en Ciberseguridad (ROI/ROSI)

Pregunta: ¿Ha cuantificado ROI de inversión en ciberseguridad?

- ☐ No realizado (0): Sin análisis
- ☐ Estimado (1): Cálculo informal
- ☐ Básico (2): ROSI simple: (Riesgo evitado - Costo solución) / Costo solución
- ☐ Integral (3): ROSI + análisis comparativo antes/después (incidentes evitados, MTTR reducido, seguros menores)
- ☐ Dinámico (4): ROSI actualizado semestralmente con datos reales de incidentes evitados + cyber insurance claims reduction

Fórmula ROSI: (Reducción Riesgo - Costo Solución) / Costo Solución

Ejemplos Históricos:

- Inversión en EDR/XDR: € [] – ROSI: []% (expectativa: >300%)

- Inversión en SIEM: € [] – ROSI: []% (expectativa: >400%)
- Inversión en MFA: € [] – ROSI: []% (expectativa: >500%)

12.3 Coste de Incidentes: Histórico y Proyectado

Pregunta: ¿Cuál fue el coste de incidentes cibernéticos en últimos 3 años?

Año	Incidentes	Coste Total	Coste Promedio por Incidente	Tendencia
2023	[]	€ []	€ []	[] ↑ [] → [] ↓
2024	[]	€ []	€ []	[] ↑ [] → [] ↓
2025	[]	€ []	€ []	[] ↑ [] → [] ↓

Desglose de Costes (último incidente significativo):

- Downtime operacional: € []
- Remediación/forensics: € []
- Costo legal/regulatorio: € []
- Daño reputacional: € []
- Seguros/deductibles: € []
- Total: € []

SECCIÓN 13: INDICADOR GLOBAL DE MADUREZ (IGM)

13.1 Auto-evaluación de Madurez por Dominio

Instrucciones: Para cada dominio NIST CSF 2.0, asigne puntuación 1-5:

Dominio	Puntuación (1-5)	Descripción del Nivel
GOBERNAR (GV)	[]	1=Inexistente, 5=Optimizado
IDENTIFICAR (ID)	[]	1=Inexistente, 5=Optimizado
PROTEGER (PR)	[]	1=Inexistente, 5=Optimizado
DETECTAR (DE)	[]	1=Inexistente, 5=Optimizado
RESPONDER (RS)	[]	1=Inexistente, 5=Optimizado
RECUPERAR (RC)	[]	1=Inexistente, 5=Optimizado

Promedio Global (IGM): $([GV] + [ID] + [PR] + [DE] + [RS] + [RC]) / 6 = [_,_]$

Interpretación IGM:

- 1.0-1.9: Maturity 0 (Caótica)
- 2.0-2.9: Maturity 1 (Inicial)
- 3.0-3.4: Maturity 2 (Gestionada)
- 3.5-4.0: Maturity 3 (Definida)
- 4.1-5.0: Maturity 4 (Optimizada)

SECCIÓN 14: OBSERVACIONES Y COMENTARIOS ADICIONALES

Pregunta Abierta: ¿Cuáles son los mayores desafíos de ciberseguridad enfrentados en últimos 12 meses?

[_____]

[_____]

Pregunta Abierta: ¿Cuáles son prioridades de ciberseguridad para próximos 12 meses?

[_____]

[_____]

Pregunta Abierta: ¿Qué inversiones en ciberseguridad planea en 2026-2027?

[_____]

[_____]

ANEXO: GLOSARIO Y DEFINICIONES

- MTTD: Mean Time To Detect (tiempo promedio detección de incidente)
- MTTC: Mean Time To Contain (tiempo promedio contención)
- MTTR: Mean Time To Recover (tiempo promedio recuperación total)
- RTO: Recovery Time Objective (objetivo de tiempo recuperación)
- RPO: Recovery Point Objective (objetivo de punto recuperación)
- CVSS: Common Vulnerability Scoring System (severidad teórica 0-10)
- EPSS: Exploit Prediction Scoring System (probabilidad explotación real)
- SIEM: Security Information and Event Management
- SOAR: Security Orchestration Automation Response
- EDR/XDR: Endpoint Detection & Response / Extended Detection & Response
- MFA: Multi-Factor Authentication
- CRITIS: Infraestructura Crítica (operadores esenciales NIS2)
- IGM: Índice Global Madurez (promedio NIST CSF)
- FAIR: Factor Analysis of Information Risk
- SBOM: Software Bill of Materials
- DLP: Data Loss Prevention
- PAM: Privileged Access Management
- IAM: Identity and Access Management
- UEBA: User and Entity Behavior Analytics

Fin del Modelo de Encuesta Integral

Descargue este documento en formato .md para implementar en su plataforma LMS o sistema de encuestas (Google Forms, Qualtrics, SurveySparrow, etc.)